Fiche 3 : l'injection de commande

Certaines applications lancent une commande système à partir de ce que tape l'utilisateur, par exemple un ping vers une adresse. Si la saisie est ajoutée telle quelle à la commande, on peut y glisser une deuxième commande.

Ce qui peut aider

Sous Linux, plusieurs caractères permettent d'enchaîner des commandes sur une même ligne :

- `;` lance la deuxième commande après la première, quoi qu'il arrive ;
- `&&` la lance seulement si la première a réussi ;
- `|` envoie la sortie de la première à la deuxième.

Pour explorer le serveur, `ls` et `cat` suffisent.

Comment s'en protéger

Éviter de passer par le shell, et vérifier que la saisie a bien la forme attendue (ici une adresse IP) avant de l'utiliser.